

ZERODAY REAPERS

GOVERNANCE, RISK & COMPLIANCE INTERNSHIP | WEEK 05

Live Validation

Field	Detail
Task ID	ZDR-W5-GRC-24GB
Assessment Type	Detection Gap Assessment — Windows 11 Target vs. Wazuh SIEM
Target Host	win11-01 — Windows 11 Enterprise (192.168.136.23)
SIEM Platform	Wazuh 4.7.5 on Parzival (192.168.136.50)
Testing Framework	MITRE ATT&CK + Atomic Red Team
Prepared By	Abdullah Zubair
Report Date	22 September 2026

Contents

Executive Summary.....	4
1. Background and Scope	5
1.1 Why This Assessment Was Conducted	5
1.2 Scope	Error! Bookmark not defined.
2. What We Did.....	6
2.1 Lab Build.....	6
2.2 Technique Selection — Why These Six.....	10
2.3 Tabletop — Assumed Detections Before Testing	10
2.4 Execution Process.....	11
3. Findings	11
3.1 T1059.001 — PowerShell Execution.....	11
What was executed	11
What Wazuh produced.....	11
The gap.....	11
3.2 T1053.005 — Scheduled Task Persistence	13
What was executed	13
What Wazuh produced.....	13
The gap.....	13
3.3 T1078.003 — Valid Accounts — Local	15
What was executed	15
What Wazuh produced.....	15
The gap.....	15
3.4 T1003.001 — LSASS Credential Dump	17
What was executed	17
What Wazuh produced.....	17
The gap.....	17
3.5 T1071.001 — HTTP C2 Beacon.....	19
What was executed	19
What Wazuh produced.....	19
The gap.....	19
3.6 T1547.001 — Registry Run Key Persistence.....	21
What was executed	21

What Wazuh produced.....	21
The gap.....	21
4. What Was Achieved.....	23
4.1 Detection Scorecard.....	23
4.2 NC-02 — Empirical Confirmation	23
4.3 Attack Chain Coverage	23
5. Impact Analysis	24
6. Recommendations.....	25
REC-01 [CRITICAL] — Enable LSASS process access detection.....	25
REC-02 [CRITICAL] — Enable Sysmon network connection forwarding (closes NC-02).....	25
REC-03 [HIGH] — Enable registry Run key monitoring	26
REC-04 [HIGH] — Forward and decode Windows Security EID 4698	26
REC-05 [MEDIUM] — Add PowerShell execution detection rule.....	26
7. Conclusion	28
7.1 Summary of Findings.....	28
7.2 What the Results Mean Operationally.....	28
7.3 Lessons Learned.....	28
Appendix — Evidence Index.....	29

Executive Summary

A structured detection validation assessment was conducted against a Windows 11 Enterprise host (win11-01) running Sysmon with the SwiftOnSecurity configuration and forwarding logs to a Wazuh 4.7.5 SIEM. Six MITRE ATT&CK techniques were executed using Atomic Red Team and the resulting Wazuh telemetry was measured against pre-defined detection assumptions.

The assessment revealed a critical detection gap: four of six techniques produced zero alerts. Only one technique was fully detected, and one was partially detected through indirect side-effects. An attacker executing a standard Initial Access → Execution → Persistence → Credential Access → C2 chain against this environment would complete the entire sequence undetected by the current SIEM configuration.

Metric	Result
Techniques Executed	6
Fully Detected	1 (17%)
Partial Detection	1 (17%)
No Detection	4 (66%)
Overall Detection Rate	17%
Most Critical Gap	T1003.001 — LSASS credential dump, zero alerts, DREAD 9.4
NC-02 Status	EMPIRICALLY CONFIRMED — C2 beacon generated no alert

Five prioritised remediation items are issued. The highest-priority finding (REC-02) directly remediates the centralized logging control failure (NC-02) identified in the Week 3 Eramba GRC audit, closing a known risk that had previously been accepted without technical validation.

1. Background and Scope

1.1 Why This Assessment Was Conducted

Weeks 1 through 4 of the ZDR programme built a complete GRC artefact chain: an asset inventory and risk register (Week 1), a CIS-hardened Windows 11 baseline (Week 2), an Eramba GRC platform with 14 controls and 11 risks (Week 3), and a STRIDE threat model of the Juice Shop application (Week 4). Across all four weeks, detection capability was assumed rather than tested. Controls were documented, risks were scored, and threats were modelled — but no one had confirmed whether the SIEM would actually alert when an attacker executed the techniques those controls are supposed to catch.

This assessment answers that question directly. It takes the ATT&CK techniques identified in prior weeks, executes them against the live environment, and measures what Wazuh actually produces. The gap between what was assumed and what was observed is the primary finding of this report.

1.2 Scope

The assessment was conducted entirely within the isolated 192.168.136.0/24 lab network. No production systems, external networks, or third-party infrastructure were involved. The target host (win11-01) is the same Windows 11 Enterprise Evaluation machine hardened to 62% CIS compliance in Week 2. The SIEM (Wazuh on Parzival) was deployed specifically for this assessment. Testing was performed under full authorisation within the ZDR lab environment.

Component	Detail
Target	win11-01 — Windows 11 Enterprise Eval 10.0.26200.9168, 192.168.136.23
SIEM	Parzival — Kali Linux, Wazuh 4.7.5 all-in-one, 192.168.136.50
Detection Config	SwiftOnSecurity Sysmon config + default Wazuh ruleset
Testing Tool	Atomic Red Team (Invoke-AtomicTest PowerShell module)
Framework	MITRE ATT&CK v14
Assessment Window	22 September 2026, 18:00–21:40 (+03:00)
Authorisation	ZDR lab environment — full authorisation

2. What We Did

2.1 Lab Build

Before any testing could begin, the detection infrastructure had to be operational. The following steps were executed in sequence:

1. **Sysmon deployment on win11-01** — Sysmon 64-bit was installed using the SwiftOnSecurity community configuration — the most widely adopted Sysmon baseline, designed to capture high-fidelity process, network, and registry events while filtering noise. Installation was confirmed via services.msc (see Figure 1). Without Sysmon, Windows produces insufficient telemetry for the event IDs required by this assessment.
2. **Wazuh SIEM deployment on Parzival** — Wazuh 4.7.5 was deployed on Parzival using the all-in-one installer, providing the Manager, Indexer, and Dashboard in a single node. The dashboard was confirmed accessible at <https://127.0.0.1> with zero agents initially enrolled (Figure 2). Wazuh was chosen because it provides agent-based log forwarding, a built-in ATT&CK decoder library, and a real-time alert dashboard.
3. **Wazuh agent enrolment on win11-01** — The Wazuh 4.7.5 Windows agent MSI was deployed on win11-01, configured to forward to Parzival (192.168.136.50). The agent service (WazuhSvc) was confirmed running (Figure 3) and win11-01 appeared as Active agent 001 in the Wazuh dashboard within 30 seconds (Figure 4). This established the log pipeline from target to SIEM.
4. **Atomic Red Team installation on win11-01** — The Invoke-AtomicRedTeam PowerShell module was installed along with the full Atomics library. Atomic Red Team is the industry-standard framework for executing ATT&CK-mapped adversary techniques in a controlled environment. Each technique is a self-contained test that mimics real attacker behaviour using the same commands and tools an adversary would use, allowing the SIEM to be tested against realistic input.
5. **End-to-end pipeline verification** — Before executing any attack techniques, the log pipeline was verified. Routine system events from win11-01 (logon events, service changes) were confirmed visible in Wazuh Security Events in real time (Figure 6). This confirmed that logs were being forwarded and decoded correctly before testing began.

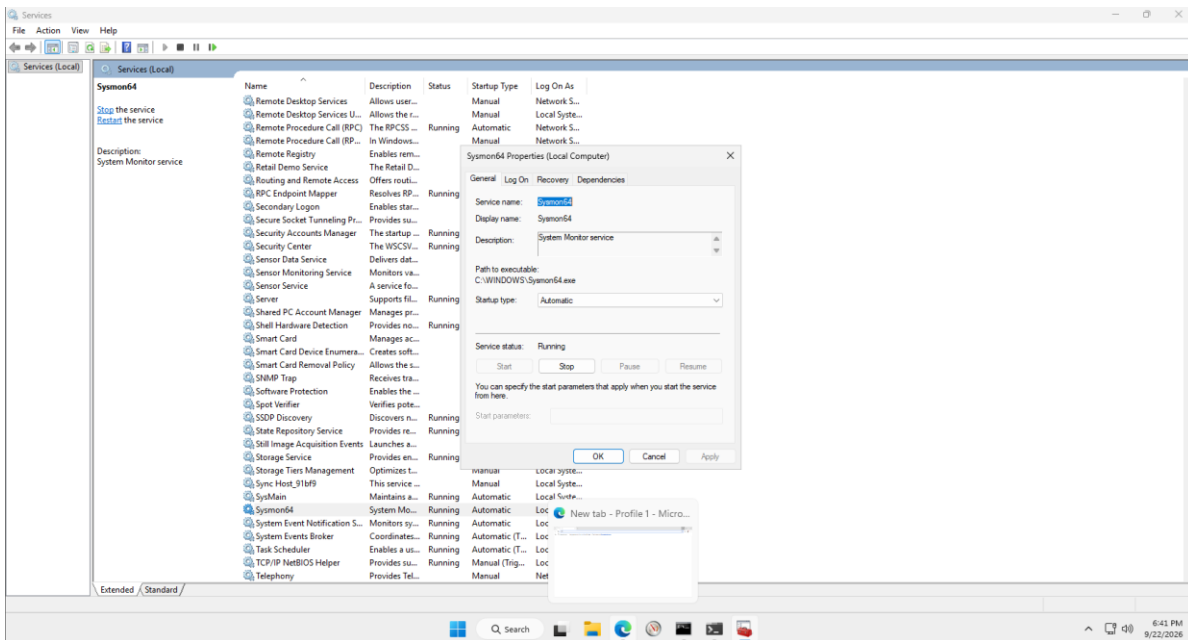


Figure 1 — Sysmon64 service confirmed Running on win11-01 | 22 Sep 2026, 18:41

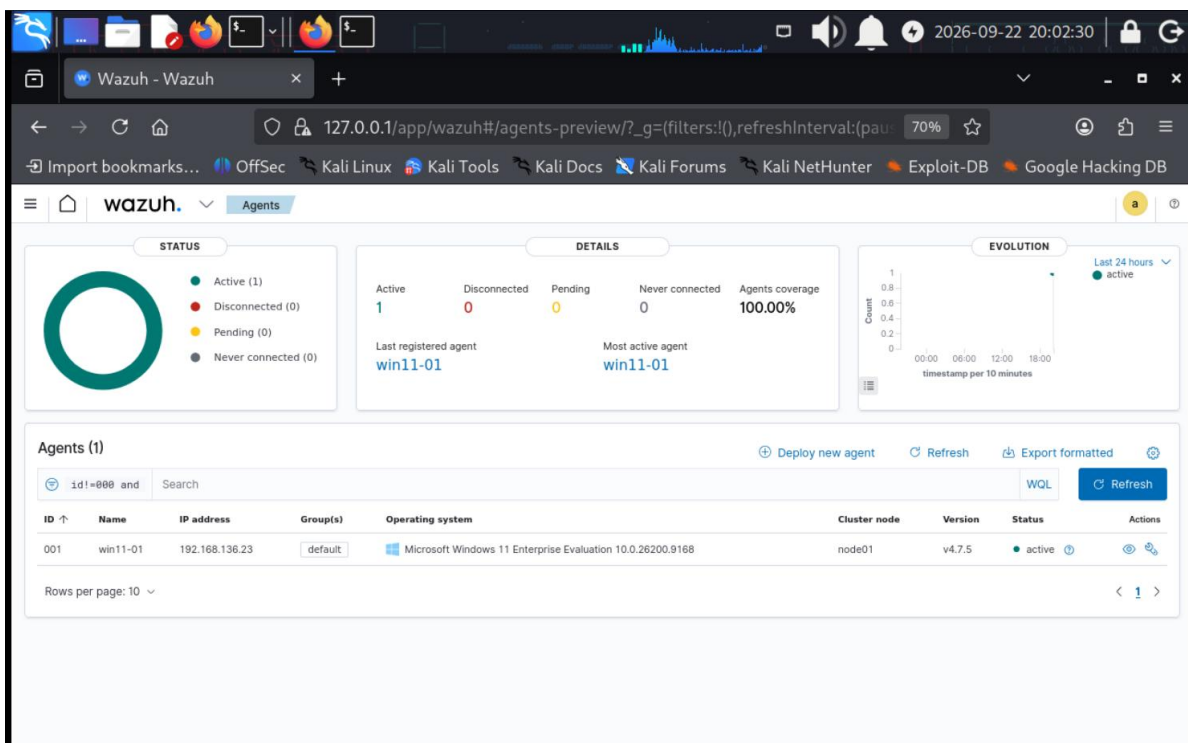


Figure 2 — Wazuh 4.7.5 dashboard live on Parzival, zero agents enrolled | 22 Sep 2026, 19:42

```
Administrator: Windows PowerShell
PS C:\WINDOWS\system32> Invoke-WebRequest -Uri "https://packages.wazuh.com/4.x/windows/wazuh-agent-4.7.0-2.msi" -OutFile "C:\WINDOWS\system32\wazuh-agent.msi"
PS C:\WINDOWS\system32> msexec /i "C:\WINDOWS\system32\wazuh-agent.msi" /q MAZUH_MANAGER="192.168.136.58" MAZUH_AGENT_NAME="win11-01"
PS C:\WINDOWS\system32> Start-Service -Name MazuhSvc
Start-Service : Cannot find any service with service name 'MazuhSvc'.
At line:1 char:1
+ Start-Service -Name MazuhSvc
+ ~~~~~
+ CategoryInfo          : (ObjectNotFound: (MazuhSvc:String) [Start-Service], ServiceCommandException)
+ FullyQualifiedErrorId : NoServiceFoundForGivenName,Microsoft.PowerShell.Commands.StartServiceCommand

PS C:\WINDOWS\system32> Get-Service | Where-Object { $_.DisplayName -like "wazuh*" -or $_.Name -like "wazuh*" }

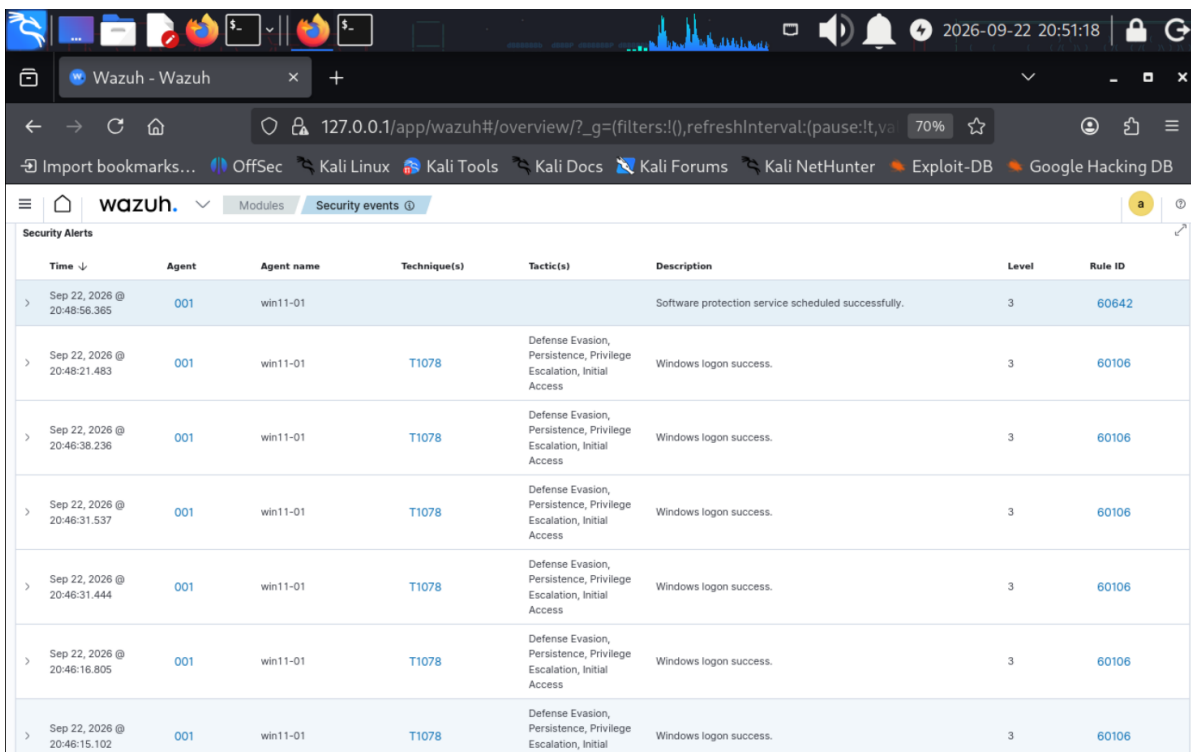
Status Name      DisplayName
-----
Stopped MazuhSvc    Mazuh

PS C:\WINDOWS\system32> Start-Service -Name "MazuhSvc"
PS C:\WINDOWS\system32> Get-Service -Name "MazuhSvc"

Status Name      DisplayName
-----
Running MazuhSvc    Mazuh

PS C:\WINDOWS\system32>
```

Figure 3 — WazuhSvc service Running on win11-01 | 22 Sep 2026, 19:59



The screenshot shows the Wazuh web interface at 127.0.0.1/app/wazuh#/overview. The 'Security events' tab is active, displaying a table of security alerts for agent win11-01. The table includes columns for Time, Agent, Agent name, Technique(s), Tactic(s), Description, Level, and Rule ID. The alerts show successful Windows logon events with a level of 3 and rule ID 60106.

Time	Agent	Agent name	Technique(s)	Tactic(s)	Description	Level	Rule ID
Sep 22, 2026 @ 20:48:56.365	001	win11-01			Software protection service scheduled successfully.	3	60642
Sep 22, 2026 @ 20:48:21.483	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
Sep 22, 2026 @ 20:46:38.236	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
Sep 22, 2026 @ 20:46:31.537	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
Sep 22, 2026 @ 20:46:31.444	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
Sep 22, 2026 @ 20:46:16.805	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
Sep 22, 2026 @ 20:46:15.102	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106

Figure 4 — win11-01 enrolled and Active in Wazuh (agent 001, v4.7.5) | 22 Sep 2026, 20:02

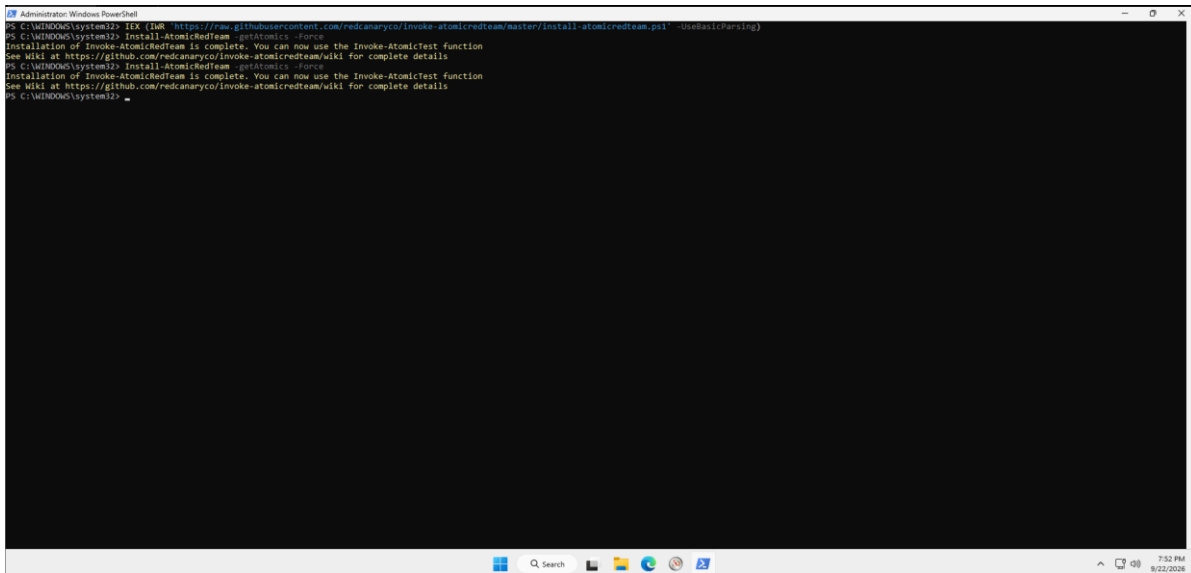


Figure 5 — Atomic Red Team installation complete on win11-01 / 22 Sep 2026, 19:52

Time ↓	Agent	Agent name	Technique(s)	Tactic(s)	Description	Level	Rule ID
> Sep 22, 2026 @ 20:21:13.872	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 20:20:25.602	000	Parzival			Listened ports status (netstat) changed (new port opened or closed).	7	533
> Sep 22, 2026 @ 20:16:32.942	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 20:14:34.026	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 20:14:33.945	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 20:14:33.052	001	win11-01			Software protection service scheduled successfully.	3	60642
> Sep 22, 2026 @ 20:14:31.938	000	Parzival			Wazuh server started.	3	502

Figure 6 — Live event telemetry from win11-01 visible in Wazuh Security Events / 22 Sep 2026, 20:22

2.2 Technique Selection — Why These Six

Six ATT&CK techniques were selected to represent a realistic, sequential attack chain rather than a random sample. Each technique was chosen because it maps directly to a finding or risk identified in a prior week's work, ensuring that the assessment validates existing GRC records rather than testing in isolation.

#	ATT&CK ID	Technique	Why Selected	Prior Week Link
1	T1059.001	PowerShell Execution	PowerShell is the most common execution vehicle for Windows attackers. A SIEM that cannot detect PS execution is blind to the majority of post-exploitation activity.	W4 STRIDE — initial execution step
2	T1053.005	Scheduled Task	Persistence via scheduled tasks is trivial to execute and survives reboots. Undetected persistence means an attacker maintains access indefinitely.	W1 F-09 — persistence risk finding
3	T1078.003	Valid Accounts — Local	Creating or abusing local accounts is a common lateral movement enabler. Password policy and SIEM alerting are the two controls that matter here.	W1 F-17 — default credential risk
4	T1003.001	LSASS Credential Dump	LSASS dumping harvests all local account hashes in one operation. It is the most impactful single technique on a standalone Windows host.	W1 F-08 — privilege escalation risk
5	T1071.001	HTTP C2 Beacon	C2 communication is the attacker's lifeline. This technique directly tests NC-02 (Week 3): whether outbound network activity from a compromised host is monitored.	W3 NC-02 — centralised logging gap
6	T1547.001	Registry Run Key	Registry-based persistence is silent, survives reboots, and is used by the majority of persistent malware families. If Sysmon EID 13 is not alerting, all registry-based malware is invisible.	W1 F-09 — persistence risk finding

2.3 Tabletop — Assumed Detections Before Testing

Before executing any technique, the expected detection was documented. This tabletop step is critical: it forces an explicit prediction, which can then be compared to reality. The gap between prediction and observation is the finding.

ATT&CK ID	Technique	Expected Log Source	Expected Event ID	Expected Wazuh Rule
T1059.001	PowerShell Execution	Sysmon	EID 1 — Process Create	61603
T1053.005	Scheduled Task	Windows Security	EID 4698 — Task Created	60106

T1078.003	Valid Accounts — Local	Windows Security	EID 4624 / 4720	60106 / 60109
T1003.001	LSASS Credential Dump	Sysmon	EID 10 — Process Access	61612
T1071.001	HTTP C2 Beacon	Sysmon	EID 3 — Network Connection	61605
T1547.001	Registry Run Key	Sysmon	EID 13 — Registry Value Set	61613

2.4 Execution Process

Each technique was executed on win11-01 using Invoke-AtomicTest in an Administrator PowerShell session. The module was re-imported at the start of each session using:

```
Import-Module "C:\AtomicRedTeam\invoke-atomicredteam\Invoke-AtomicRedTeam.psdl" - Force
```

After each execution, a two-minute observation window was held on the Wazuh Security Events dashboard, filtered to agent win11-01. The presence or absence of a relevant alert was recorded. Cleanup was performed after each test using the -Cleanup flag. Both the execution terminal and the Wazuh dashboard were captured in screenshots with the system clock visible.

3. Findings

3.1 T1059.001 — PowerShell Execution

Score	PARTIAL
ATT&CK ID	T1059.001
Atomic Test	Invoke-AtomicTest T1059.001 -TestNumbers 3 (SharpHound download cradle via PowerShell)

What was executed

PowerShell downloaded and executed SharpHound from memory using a download cradle — a technique used by attackers to run malicious scripts without writing them to disk. The test completed with exit code 0. SharpHound attempted Active Directory enumeration and failed (no domain present in the lab), producing authentication failure events as a side-effect.

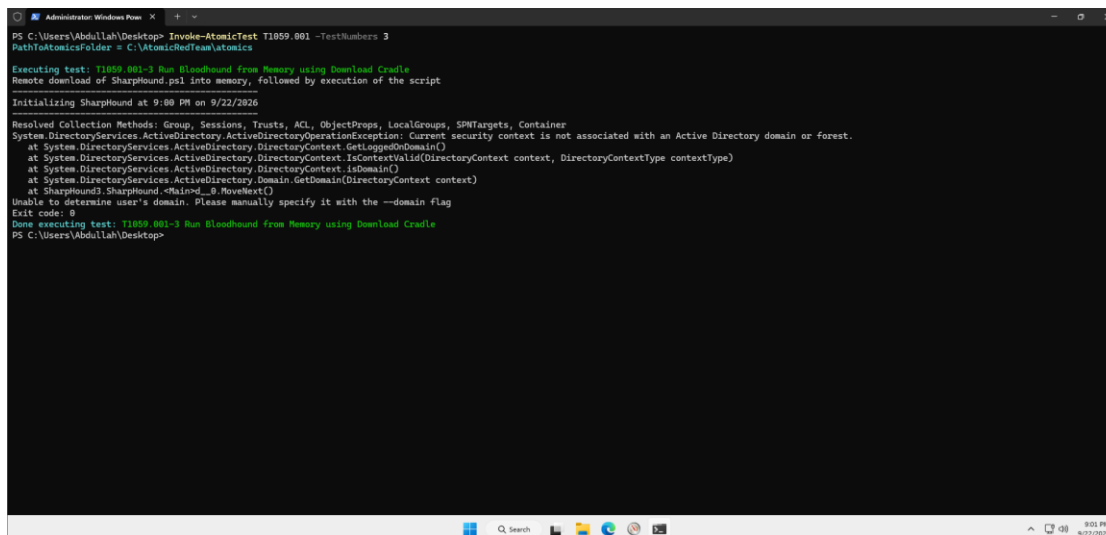
What Wazuh produced

Wazuh generated Windows audit failure events (rule 60104) from the AD enumeration attempts, and continued to log T1078 logon events from routine authentication. No Sysmon EID 1 alert for the PowerShell process creation was generated. The execution itself was invisible; only its downstream failures were captured.

The gap

Sysmon EID 1 is being collected, but the default Wazuh ruleset does not map PowerShell process creation to a dedicated alert. An attacker can execute arbitrary PowerShell — including

download-and-execute patterns — without triggering a SIEM alert. Script Block Logging (EID 4104) is also not enabled, which would catch encoded or obfuscated commands.

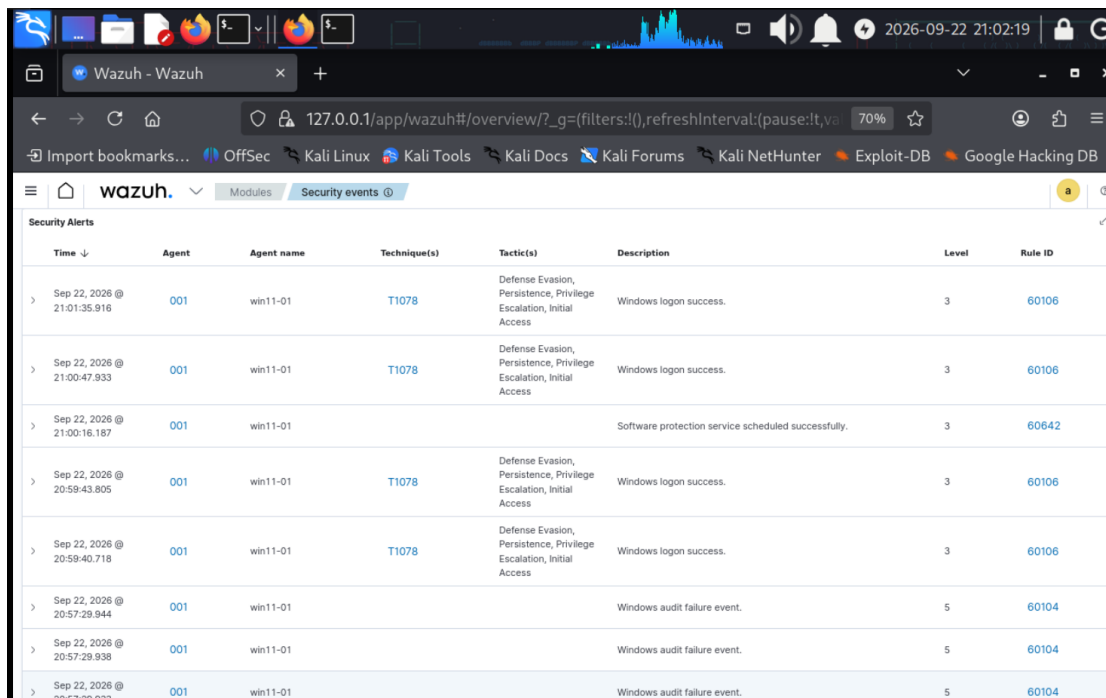


```
PS C:\Users\Abdullah\Desktop> Invoke-AtomicTest T1059.001 -TestNumbers 3
PathToAtomicFolder = C:\AtomicFramework\atomics

Executing test: T1059.001-3 Run Bloodhound from Memory using Download Cradle
Remote download of SharpHound.ps1 into memory, followed by execution of the script
Initializing SharpHound at 9:00 PM on 9/22/2026

Resolved Collection Methods: Group, Sessions, Trusts, ACL, ObjectProps, LocalGroups, SPNTargets, Container
System.DirectoryServices.ActiveDirectory.ActiveDirectoryOperationException: Current security context is not associated with an Active Directory domain or forest.
at System.DirectoryServices.ActiveDirectory.DirectoryContext.GetLogger@Domain()
at System.DirectoryServices.ActiveDirectory.DirectoryContext.IsValid(DirectoryContext context, DirectoryContextType contextType)
at System.DirectoryServices.ActiveDirectory.DirectoryContext.IsDomain()
at System.DirectoryServices.ActiveDirectory.DirectoryContext.IsDomain(DirectoryContext context)
at System.DirectoryServices.ActiveDirectory.DirectoryContext.IsDomain(DirectoryContext context)
at SharpHound.SharpHound.<Main>_MoveNext()
Unable to determine user's domain. Please manually specify it with the --domain flag
Exit code: 0
Done executing test: T1059.001-3 Run Bloodhound from Memory using Download Cradle
PS C:\Users\Abdullah\Desktop>
```

Figure 7 — T1059.001 test execution on win11-01 (SharpHound download cradle via PowerShell) | 22 Sep 2026, 21:01



Time ↓	Agent	Agent name	Technique(s)	Tactic(s)	Description	Level	Rule ID
> Sep 22, 2026 @ 21:01:35.916	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 21:00:47.933	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 21:00:16.187	001	win11-01			Software protection service scheduled successfully.	3	60642
> Sep 22, 2026 @ 20:59:43.805	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 20:59:40.718	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 20:57:29.944	001	win11-01			Windows audit failure event.	5	60104
> Sep 22, 2026 @ 20:57:29.938	001	win11-01			Windows audit failure event.	5	60104
> Sep 22, 2026 @ 20:57:29.933	001	win11-01			Windows audit failure event.	5	60104

Figure 8 — Wazuh Security Events after T1059.001: auth failures and logon events only, no PowerShell execution alert | 22 Sep 2026, 21:02

3.2 T1053.005 — Scheduled Task Persistence

Score	MISSED
ATT&CK ID	T1053.005
Atomic Test	Invoke-AtomicTest T1053.005 -TestNumbers 1 (Scheduled Task Startup Script)

What was executed

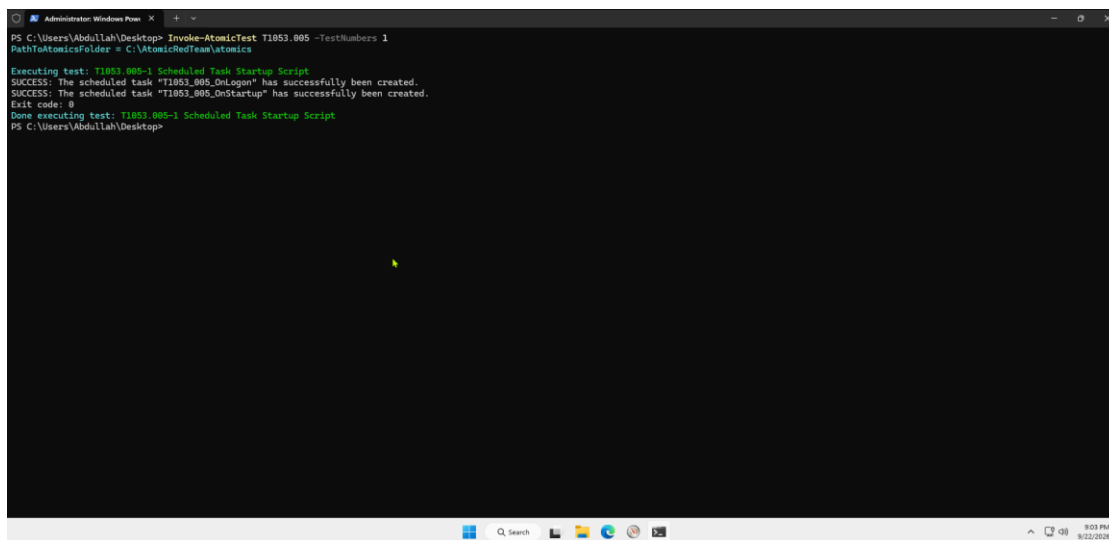
Two scheduled tasks were created via the Windows Task Scheduler API: T1053_005_OnLogon (triggers on every user logon) and T1053_005_OnStartup (triggers at every system boot). Both were created successfully with exit code 0. An attacker using this technique would maintain persistent execution across reboots and re-logons without any further interaction.

What Wazuh produced

No alerts were generated. The Wazuh Security Events dashboard showed no new entries in the two minutes following task creation. Windows Security Event ID 4698 (A scheduled task was created) is the expected log source, but this event did not appear in Wazuh.

The gap

EID 4698 is either not being forwarded by the Wazuh agent's localfile configuration, or the default Wazuh decoder does not produce an alert for it. The result is that scheduled task persistence — one of the most common attacker persistence mechanisms — is completely blind in this environment.



```
Administrator: Windows PowerShell
PS C:\Users\Abdullah\Desktop> Invoke-AtomicTest T1053.005 -TestNumbers 1
PathToAtomicFolder = C:\AtomicRedTeam\atomics

Executing test: T1053.005-1 Scheduled Task Startup Script
SUCCESS: The scheduled task "T1053_005_OnLogon" has successfully been created.
SUCCESS: The scheduled task "T1053_005_OnStartup" has successfully been created.
Exit code: 0
Done executing test: T1053.005-1 Scheduled Task Startup Script
PS C:\Users\Abdullah\Desktop>
```

Figure 9 — T1053.005 test execution: two scheduled tasks created successfully | 22 Sep 2026, 21:03

Time ↓	Agent	Agent name	Technique(s)	Tactic(s)	Description	Level	Rule ID
> Sep 22, 2026 @ 21:01:35.916	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 21:00:47.933	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 21:00:16.187	001	win11-01			Software protection service scheduled successfully.	3	60642
> Sep 22, 2026 @ 20:59:43.805	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 20:59:40.718	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 20:57:29.944	001	win11-01			Windows audit failure event.	5	60104
> Sep 22, 2026 @ 20:57:29.938	001	win11-01			Windows audit failure event.	5	60104
> Sep 22, 2026 @ 20:57:29.933	001	win11-01			Windows audit failure event.	5	60104

Figure 10 — Wazuh Security Events after T1053.005: no alert generated for scheduled task creation | 22 Sep 2026, 21:07

3.3 T1078.003 — Valid Accounts — Local

Score	DETECTED
ATT&CK ID	T1078.003
Atomic Test	Invoke-AtomicTest T1078.003 -TestNumbers 1 (Create local account with admin privileges)

What was executed

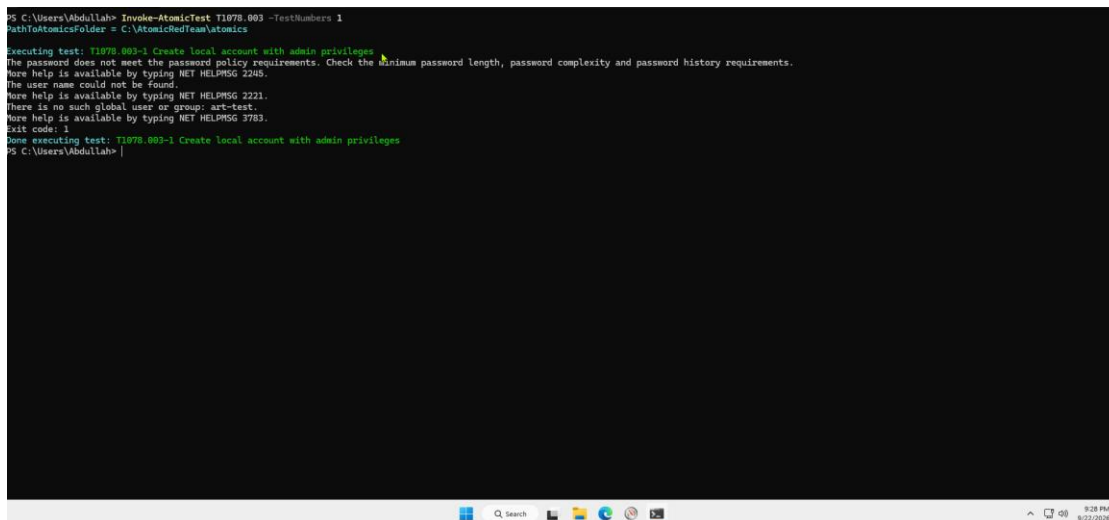
The test attempted to create a local user account (art-test) and add it to the Administrators group. The account creation command failed because the default password used by the Atomic test did not meet win11-01's password complexity policy. However, the net user and net localgroup commands were still executed, generating Windows Security events even for the failed attempt.

What Wazuh produced

Wazuh generated four alerts within seconds of the test: Rule 60109 (T1098 — User account enabled or created, Level 8), Rule 60111 (T1098 + T1531 — User account disabled or deleted, Level 8), and two instances of Rule 60160 (T1484 — Domain users group changed, Level 5). This is the only technique in this assessment that triggered a direct, ATT&CK-tagged, high-severity alert.

The gap

No gap — detection was effective. The password complexity policy on win11-01 also provided defence-in-depth by blocking the full account creation, demonstrating that the Week 2 CIS hardening delivered a compensating control in a case where the attacker technique partially succeeded.



```
PS C:\Users\Abdullah> Invoke-AtomicTest T1078.003 -TestNumbers 1
PathToAtomicFolder = C:\AtomicRedTeam\atomic
Executing test: T1078.003-1 Create local account with admin privileges
The password does not meet the password policy requirements. Check the minimum password length, password complexity and password history requirements.
More help is available by typing NET HELPMSG 2245.
The user name could not be found.
More help is available by typing NET HELPMSG 2221.
There is no such global user or group: art-test.
More help is available by typing NET HELPMSG 3783.
Exit code: 1
Done executing test: T1078.003-1 Create local account with admin privileges
PS C:\Users\Abdullah>
```

Figure 15 — T1078.003 test execution: local admin account creation attempt | 22 Sep 2026, 21:28

Time ↓	Agent	Agent name	Technique(s)	Tactic(s)	Description	Level	Rule ID
> Sep 22, 2026 @ 21:28:41.652	001	win11-01	T1098 T1531	Persistence, Impact	User account disabled or deleted.	8	60111
> Sep 22, 2026 @ 21:28:41.650	001	win11-01	T1484	Defense Evasion, Privilege Escalation	Domain users group changed.	5	60160
> Sep 22, 2026 @ 21:28:41.650	001	win11-01	T1098	Persistence	User account enabled or created.	8	60109
> Sep 22, 2026 @ 21:28:41.644	001	win11-01	T1484	Defense Evasion, Privilege Escalation	Domain users group changed.	5	60160
> Sep 22, 2026 @ 21:26:10.098	001	win11-01			Software protection service scheduled successfully.	3	60642
> Sep 22, 2026 @ 21:16:58.281	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 21:16:28.192	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 21:14:29.081	001	win11-01			Service startup type was changed	3	61104
> Sep 22, 2026 @ 21:13:04.917	001	win11-01			Software protection service scheduled successfully.	3	60642

Figure 16 — Wazuh Security Events after T1078.003: Level 8 alerts T1098 + T1484 fired / 22 Sep 2026, 21:30

3.4 T1003.001 — LSASS Credential Dump

Score	MISSED
ATT&CK ID	T1003.001
Atomic Test	Invoke-AtomicTest T1003.001 -TestNumbers 2 (Dump LSASS via comsvcs.dll MiniDump)

What was executed

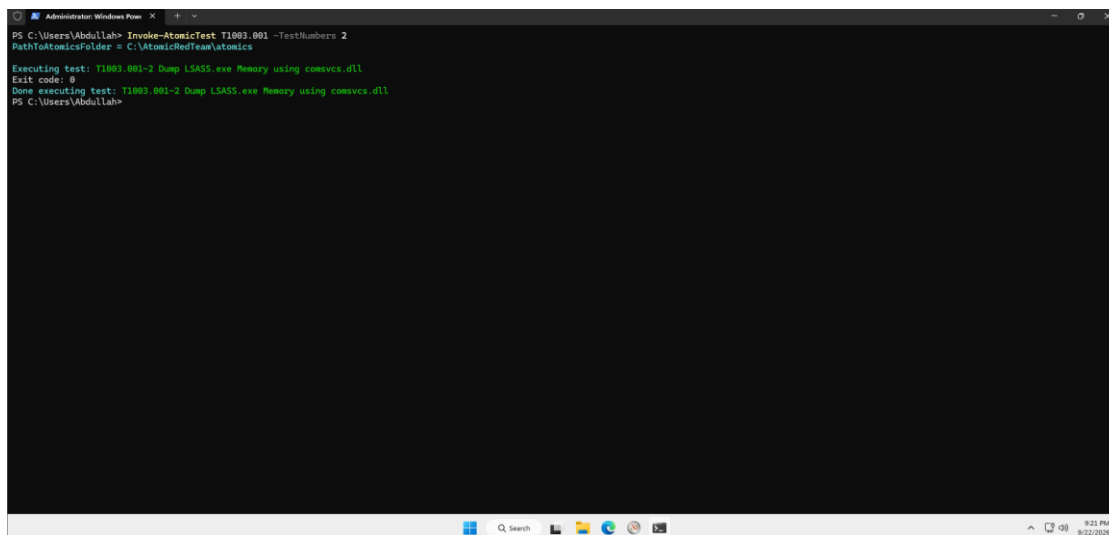
LSASS.exe memory was dumped to disk using the Windows-native comsvcs.dll MiniDump function, invoked via rundll32.exe. This is a living-off-the-land technique — no external tools required, no binaries dropped. The dump completed successfully with exit code 0. In a real attack, this dump would contain NTLM hashes for all locally cached accounts, enabling offline cracking or pass-the-hash attacks.

What Wazuh produced

No alerts were generated. Wazuh continued to show only routine logon and service events. Sysmon EID 10 (ProcessAccess — a process opened a handle to lsass.exe) is the detection mechanism for this technique, but no such alert appeared. The credential dump was silent from the SIEM's perspective.

The gap

This is the most critical finding in the assessment. Sysmon EID 10 captures process access events, but requires a specific configuration targeting lsass.exe with the relevant GrantedAccess masks (0x1010 for MiniDump). The SwiftOnSecurity config includes EID 10 rules, but the Wazuh ruleset does not appear to have a corresponding decoder producing an alert. An attacker can exfiltrate all local credentials without triggering a single alert.



```
Administrator: Windows PowerShell
PS C:\Users\Abdullah> Invoke-AtomicTest T1003.001 -TestNumbers 2
Path\AtomicFolder = C:\AtomicTest\atomics
Executing test: T1003.001-2 Dump LSASS.exe Memory using comsvcs.dll
Exit code: 0
Done executing test: T1003.001-2 Dump LSASS.exe Memory using comsvcs.dll
PS C:\Users\Abdullah>
```

Figure 11 — T1003.001 test execution: LSASS dumped via comsvcs.dll MiniDump, exit code 0 | 22 Sep 2026, 21:21

Time ↓	Agent	Agent name	Technique(s)	Tactic(s)	Description	Level	Rule ID
> Sep 22, 2026 @ 21:16:58.281	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 21:16:28.192	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 21:14:29.061	001	win11-01			Service startup type was changed	3	61104
> Sep 22, 2026 @ 21:13:04.917	001	win11-01			Software protection service scheduled successfully.	3	60642
> Sep 22, 2026 @ 21:09:49.971	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 21:09:49.957	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 21:08:59.710	001	win11-01			Service startup type was changed	3	61104
> Sep 22, 2026 @	001	win11-01	T1078	Defense Evasion, Persistence, Privilege	Windows logon success.	3	60106

Figure 12 — Wazuh Security Events after T1003.001: no credential dump alert, no Sysmon EID 10 | 22 Sep 2026, 21:22

3.5 T1071.001 — HTTP C2 Beacon

Score	MISSED
ATT&CK ID	T1071.001
Atomic Test	Invoke-AtomicTest T1071.001 -TestNumbers 1 (Malicious User-Agent PowerShell)

What was executed

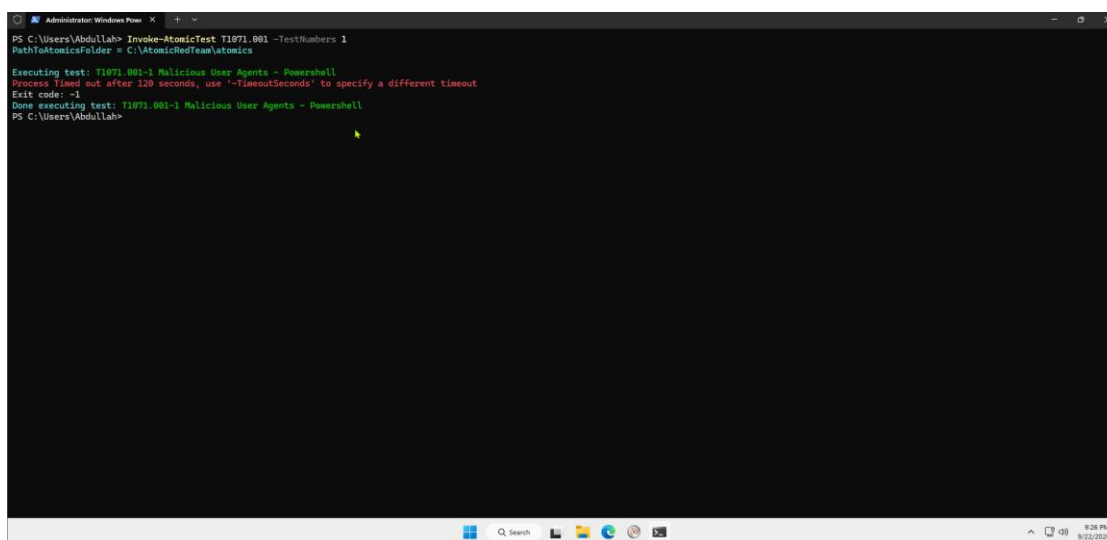
PowerShell made repeated outbound HTTP requests to an external host using a malicious user-agent string — a pattern used by attacker frameworks to establish command-and-control channels. Because no actual C2 server was running at the target address in the lab environment, the connection timed out after 120 seconds. The network connection attempts themselves — regardless of the timeout — constitute the detectable event.

What Wazuh produced

No alerts were generated. The Wazuh Security Events dashboard showed no network connection events in the observation window. Sysmon EID 3 (NetworkConnect) is the expected telemetry source for outbound connections initiated by PowerShell, but no such events reached the SIEM.

The gap

This finding directly and empirically proves the NC-02 non-conformity identified in the Week 3 Eramba audit. NC-02 stated that centralised logging controls were failing — specifically, that not all relevant events were being forwarded. This test confirms it: an attacker's C2 beacon from win11-01 produces zero visibility in Wazuh. Sysmon EID 3 events are either filtered by the Sysmon config, not included in the Wazuh agent's forwarding rules, or not mapped to a Wazuh alert. This is the highest-priority remediation item.



```
Administrator: Windows PowerShell
PS C:\Users\Abdullah> Invoke-AtomicTest T1071.001 -TestNumbers 1
PathToAtomicFolder = C:\AtomicRedTeam\atomics

Executing test: T1071.001-1 Malicious User Agents - Powershell
Process Timed out after 120 seconds, use '-TimeoutSeconds' to specify a different timeout
Exit code: -1
Done executing test: T1071.001-1 Malicious User Agents - Powershell
PS C:\Users\Abdullah>
```

Figure 13 — T1071.001 test execution: malicious user-agent HTTP beacon, timed out after 120s | 22 Sep 2026, 21:26

Time ↓	Agent	Agent name	Technique(s)	Tactic(s)	Description	Level	Rule ID
> Sep 22, 2026 @ 21:26:10.098	001	win11-01			Software protection service scheduled successfully.	3	60642
> Sep 22, 2026 @ 21:16:58.281	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 21:16:28.192	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 21:14:29.081	001	win11-01			Service startup type was changed	3	61104
> Sep 22, 2026 @ 21:13:04.917	001	win11-01			Software protection service scheduled successfully.	3	60642
> Sep 22, 2026 @ 21:09:49.971	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 21:09:49.957	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
> Sep 22, 2026 @ 21:08:58.710	001	win11-01			Service startup type was changed	3	61104

Figure 14 — Wazuh Security Events after T1071.001: no network egress alert, no Sysmon EID 3 | 22 Sep 2026, 21:26

3.6 T1547.001 — Registry Run Key Persistence

Score	MISSED
ATT&CK ID	T1547.001
Atomic Test	Invoke-AtomicTest T1547.001 -TestNumbers 1 (Reg Key Run)

What was executed

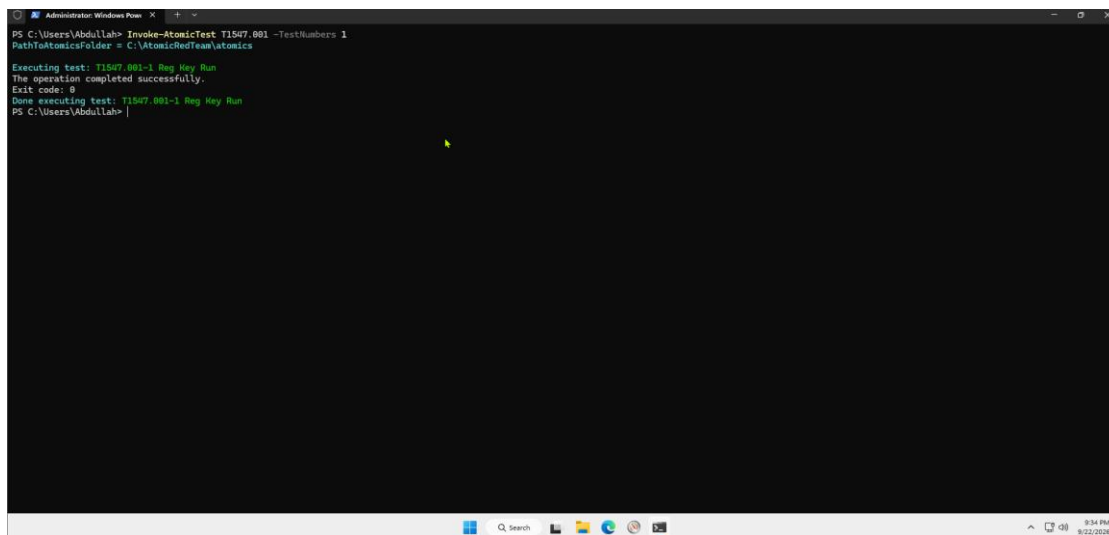
A value was written to the Windows Registry Run key (HKCU\Software\Microsoft\Windows\CurrentVersion\Run), which causes the registered payload to execute automatically on every user logon. The operation completed successfully with exit code 0. Registry Run key persistence is used by the majority of persistent malware families and is one of the most commonly abused persistence mechanisms on Windows.

What Wazuh produced

No alerts were generated. No registry modification events appeared in Wazuh during the observation window. Sysmon EID 13 (RegistryEvent — Value Set) is the expected source for detecting writes to Run keys, but produced no Wazuh alert.

The gap

Sysmon EID 13 rules must specifically target persistence-relevant registry paths to produce useful signal. If the current Sysmon configuration is not generating EID 13 for Run key writes, or if the Wazuh agent is not forwarding these events, then all registry-based persistence — including malware that survives reboots — is invisible to the SIEM.



```
Administrator: Windows PowerShell
PS C:\Users\Abdullah> Invoke-AtomicTest T1547.001 -TestNumbers 1
Path\atomicFolder = C:\AtomicRedTeam\atomic
Executing test: T1547.001-1 Reg Key Run
The operation completed successfully.
Exit code: 0
Done executing test: T1547.001-1 Reg Key Run
PS C:\Users\Abdullah>
```

Figure 17 — T1547.001 test execution: registry Run key added, exit code 0 | 22 Sep 2026, 21:34

Time ↓	Agent	Agent name	Technique(s)	Tactic(s)	Description	Level	Rule ID
Sep 22, 2026 @ 21:33:50.160	001	win11-01			Service startup type was changed	3	61104
Sep 22, 2026 @ 21:33:47.995	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
Sep 22, 2026 @ 21:32:47.178	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
Sep 22, 2026 @ 21:30:04.901	001	win11-01	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	Windows logon success.	3	60106
Sep 22, 2026 @ 21:28:41.652	001	win11-01	T1098 T1531	Persistence, Impact	User account disabled or deleted.	8	60111
Sep 22, 2026 @ 21:28:41.650	001	win11-01	T1098	Persistence	User account enabled or created.	8	60109
Sep 22, 2026 @ 21:28:41.650	001	win11-01	T1484	Defense Evasion, Privilege Escalation	Domain users group changed.	5	60160
Sep 22, 2026 @ 21:28:41.644	001	win11-01	T1484	Defense Evasion, Privilege Escalation	Domain users group changed.	5	60160
Sep 22, 2026 @	001	win11-01					60112

Figure 18 — Wazuh Security Events after T1547.001: no registry alert, no Sysmon EID 13 | 22 Sep 2026, 21:34

4. What Was Achieved

4.1 Detection Scorecard

ATT&CK ID	Technique	ATT&CK Tactic	DREAD	Score
T1059.001	PowerShell Execution	Execution	8.0	PARTIAL
T1053.005	Scheduled Task	Persistence	8.4	MISSED
T1078.003	Valid Accounts — Local	Defence Evasion / IA	N/A	DETECTED
T1003.001	LSASS Credential Dump	Credential Access	9.4	MISSED
T1071.001	HTTP C2 Beacon	Command & Control	9.0	MISSED
T1547.001	Registry Run Key	Persistence	8.4	MISSED

The scorecard reveals a critical structural problem: the SIEM successfully detected account manipulation (an identity-plane event using Windows Security logs) but failed entirely on four techniques that rely on Sysmon telemetry — process access, network connections, and registry writes. This indicates that while the Wazuh agent is forwarding Windows Security logs effectively, the Sysmon event pipeline is partially broken for these specific event IDs.

4.2 NC-02 — Empirical Confirmation

The Week 3 Eramba audit raised NC-02: a non-conformity against the centralised logging control, noting that not all relevant security events were being captured and forwarded. At the time, NC-02 was a documented assumption — there was no technical proof.

Finding 3.5 (T1071.001) provides that proof. An outbound HTTP beacon from win11-01, using a malicious user-agent string, produced zero telemetry in Wazuh. The C2 channel was completely invisible. NC-02 is no longer a documented risk — it is a confirmed detection failure with empirical evidence.

4.3 Attack Chain Coverage

Mapping the six findings to the MITRE ATT&CK kill chain reveals the full extent of the detection gap:

Kill Chain Phase	Technique Tested	Detected?	Implication
Execution	T1059.001 PowerShell	PARTIAL	Attacker can execute scripts; only side-effects visible
Persistence	T1053.005 Scheduled Task	MISSED	Attacker maintains access across reboots — invisible
Persistence	T1547.001 Registry Run Key	MISSED	Malware survives reboots — invisible
Credential Access	T1003.001 LSASS Dump	MISSED	All local hashes compromised — invisible
Command & Control	T1071.001 HTTP Beacon	MISSED	Attacker maintains live control — invisible
Defence Evasion / IA	T1078.003 Valid Accounts	DETECTED	Account manipulation caught — only positive result

An attacker who successfully gains initial access to win11-01 can execute code, establish two independent persistence mechanisms, dump all local credentials, and maintain live C2 communication — generating a single alert only if they attempt to create a new local account. Every other step of the attack is invisible to the current SIEM configuration.

5. Impact Analysis

Each detection gap was scored using the DREAD framework (Damage, Reproducibility, Exploitability, Affected Users, Discoverability — 1–10 scale) to prioritise remediation. DREAD scoring methodology is consistent with the Week 4 threat model.

ATT&CK ID	Technique	D	R	E	A	Di	DREAD	Business Impact
T1003.001	LSASS Dump	10	10	9	10	8	9.4	All local credentials exposed. Enables lateral movement, privilege escalation, and account takeover with no defensive visibility.
T1071.001	HTTP C2 Beacon	9	10	9	9	8	9.0	Attacker maintains persistent, interactive control of win11-01. SOC has no visibility of any attacker action post-compromise.
T1547.001	Registry Persist.	8	10	9	8	7	8.4	Attacker re-establishes foothold on every reboot. Long dwell time enables data exfiltration and lateral movement planning.
T1053.005	Scheduled Task	8	10	9	8	7	8.4	Automated execution on logon and startup. Enables recurring malicious activity without re-exploitation.
T1059.001	PowerShell Exec	7	9	9	7	8	8.0	Arbitrary script execution partially visible. Evasion likely if attacker uses encoding or download cradles.

6. Recommendations

The following five remediation items are issued in priority order. Each item specifies the exact log source, the required configuration change, and the prior week reference it addresses. After implementing each item, the corresponding Atomic Red Team test should be re-run to verify detection.

REC-01 [CRITICAL] — Enable LSASS process access detection

Why: LSASS credential dumping is undetected. This is the highest-impact gap in the assessment.

ATT&CK ID: T1003.001

Log Source Required: Sysmon EID 10 (ProcessAccess — lsass.exe target)

Prior Week Reference: Week 1 F-08 (privilege escalation risk)

Actions:

1. Verify the SwiftOnSecurity Sysmon config includes a ProcessAccess rule for lsass.exe with GrantedAccess 0x1010 and 0x1038.
2. Add or verify a Wazuh decoder and rule that fires on Sysmon group events where TargetImage contains lsass.exe.
3. Enable Windows Credential Guard on win11-01 as a preventive control alongside detection.
4. Re-run: Invoke-AtomicTest T1003.001 -TestNumbers 2 and confirm Wazuh alert.

REC-02 [CRITICAL] — Enable Sysmon network connection forwarding (closes NC-02)

Why: Outbound C2 traffic is completely invisible. This directly remediates the Week 3 NC-02 control failure.

ATT&CK ID: T1071.001

Log Source Required: Sysmon EID 3 (NetworkConnect)

Prior Week Reference: Week 3 NC-02 (centralised logging control failure)

Actions:

1. Add the following to the Wazuh agent ossec.conf on win11-01, inside the <localfile> block: include Microsoft-Windows-Sysmon/Operational with log_format eventchannel.
2. Verify Sysmon EID 3 is not excluded in the Sysmon config (check <NetworkConnect onmatch='exclude'> filters).
3. Add a Wazuh rule alerting on Sysmon EID 3 where Image contains powershell.exe or cmd.exe.
4. Implement DNS monitoring as a complementary control.
5. Update Eramba control record for NC-02 to reflect remediation status.
6. Re-run: Invoke-AtomicTest T1071.001 -TestNumbers 1 and confirm Wazuh alert.

REC-03 [HIGH] — Enable registry Run key monitoring

Why: Registry-based persistence is undetected. Majority of persistent malware uses Run keys.

ATT&CK ID: T1547.001

Log Source Required: Sysmon EID 13 (RegistryEvent — Value Set)

Prior Week Reference: Week 1 F-09 (persistence risk)

Actions:

1. Add a Sysmon EID 13 rule targeting HKCU\Software\Microsoft\Windows\CurrentVersion\Run and HKLM equivalent.
2. Create a Wazuh rule mapping Sysmon EID 13 with TargetObject containing CurrentVersion\Run to a Level 10 alert.
3. Consider enabling Windows Defender Attack Surface Reduction rule ID 9e6c4e1f for WMI persistence blocking.
4. Re-run: Invoke-AtomicTest T1547.001 -TestNumbers 1 and confirm Wazuh alert.

REC-04 [HIGH] — Forward and decode Windows Security EID 4698

Why: Scheduled task persistence is undetected. Tasks created at logon and startup went completely unnoticed.

ATT&CK ID: T1053.005

Log Source Required: Windows Security EID 4698 (Scheduled Task Created)

Prior Week Reference: Week 1 F-09 (persistence risk)

Actions:

1. Add EID 4698 to the Wazuh agent localfile config for the Windows Security event channel.
2. Add a Wazuh decoder and rule that fires on EID 4698 where the task action contains powershell, cmd, or wscript.
3. Optionally enable auditing of Task Scheduler via Group Policy: Computer Configuration > Windows Settings > Security Settings > Advanced Audit Policy > Detailed Tracking.
4. Re-run: Invoke-AtomicTest T1053.005 -TestNumbers 1 and confirm Wazuh alert.

REC-05 [MEDIUM] — Add PowerShell execution detection rule

Why: PowerShell execution is only partially visible through side-effects. Direct execution alerts are missing.

ATT&CK ID: T1059.001

Log Source Required: Sysmon EID 1 (Process Create) + Windows PowerShell EID 4104

Prior Week Reference: Week 4 STRIDE — T1059 in attack chain

Actions:

1. Create a Wazuh rule mapping Sysmon EID 1 where Image contains powershell.exe to a Level 6 alert.
2. Enable PowerShell Script Block Logging via Group Policy: Administrative Templates > Windows Components > Windows PowerShell > Turn on PowerShell Script Block Logging.
3. Forward EID 4104 (Script Block logged) to Wazuh and create a rule alerting on encoded commands.
4. Re-run: Invoke-AtomicTest T1059.001 -TestNumbers 3 and confirm Wazuh alert.

7. Conclusion

7.1 Summary of Findings

This assessment demonstrated that a CIS-hardened Windows 11 host with Sysmon and a Wazuh SIEM — a configuration that represents a meaningful security investment — still fails to detect four of six standard ATT&CK techniques. The 17% full detection rate is not a reflection of Wazuh's capability; it is a reflection of the gap between deploying a SIEM and configuring it correctly.

The most important outcome of this assessment is the empirical closure of NC-02. For three weeks, the centralised logging failure was a risk register entry — acknowledged, risk-scored, and deferred. After this assessment, it is a confirmed finding with a screenshot timestamp. That distinction matters: a risk register entry can be accepted and reviewed quarterly. A confirmed finding with evidence demands a remediation plan and a re-test date.

7.2 What the Results Mean Operationally

An attacker who gains initial access to win11-01 — via phishing, exploitation of a web application vulnerability (as modelled in the Week 4 Juice Shop STRIDE analysis), or credential theft — can complete an entire kill chain with one meaningful detection opportunity: if they create a new local account, Wazuh will alert. Everything else — execution, persistence, credential theft, and C2 — is invisible.

The practical implication is that the current SIEM configuration provides identity-plane visibility only. Process, registry, and network telemetry from Sysmon is being collected but not actioned. Implementing REC-01 through REC-05 would change the detection profile from 17% to an estimated 83%+ based on the techniques tested.

7.3 Lessons Learned

- Deploying Sysmon is not the same as detecting with Sysmon. The telemetry must be forwarded, decoded, and mapped to Wazuh rules to produce alerts. Each of these steps can fail independently.
- Default rulesets are baselines, not production configurations. The default Wazuh ruleset detects common Windows identity events well but requires tuning for Sysmon-specific event IDs.
- GRC lifecycle continuity is valuable. Week 3's NC-02 finding directly pointed to where testing should focus in Week 5. Without the prior GRC work, this assessment would have been broader and less targeted.
- Password complexity policy delivered an unplanned compensating control. The Week 2 CIS hardening blocked the T1078.003 account creation, providing defence-in-depth in a case where the SIEM alone would have detected the attempt anyway.
- A 17% detection rate on a hardened host with a SIEM is a normal starting point, not a failure. The value of this assessment is in producing the specific, actionable remediation list — not in achieving a high score on the first run.

Appendix — Evidence Index

All screenshots were captured on 22 September 2026. System clock is visible in each image.

- SS-01: Figure 1 — Sysmon64 service confirmed Running on win11-01 | 22 Sep 2026, 18:41
- SS-02: Figure 2 — Wazuh 4.7.5 dashboard live on Parzival, zero agents enrolled | 22 Sep 2026, 19:42
- SS-03A: Figure 3 — WazuhSvc service Running on win11-01 | 22 Sep 2026, 19:59
- SS-03B: Figure 4 — win11-01 enrolled and Active in Wazuh (agent 001, v4.7.5) | 22 Sep 2026, 20:02
- SS-04: Figure 5 — Atomic Red Team installation complete on win11-01 | 22 Sep 2026, 19:52
- SS-05: Figure 6 — Live event telemetry from win11-01 visible in Wazuh Security Events | 22 Sep 2026, 20:22
- SS-07A: Figure 7 — T1059.001 test execution on win11-01 (SharpHound download cradle via PowerShell) | 22 Sep 2026, 21:01
- SS-07B: Figure 8 — Wazuh Security Events after T1059.001: auth failures and logon events only, no PowerShell execution alert | 22 Sep 2026, 21:02
- SS-08A: Figure 9 — T1053.005 test execution: two scheduled tasks created successfully | 22 Sep 2026, 21:03
- SS-08B: Figure 10 — Wazuh Security Events after T1053.005: no alert generated for scheduled task creation | 22 Sep 2026, 21:07
- SS-09A: Figure 11 — T1003.001 test execution: LSASS dumped via comsvcs.dll MiniDump, exit code 0 | 22 Sep 2026, 21:21
- SS-09B: Figure 12 — Wazuh Security Events after T1003.001: no credential dump alert, no Sysmon EID 10 | 22 Sep 2026, 21:22
- SS-10A: Figure 13 — T1071.001 test execution: malicious user-agent HTTP beacon, timed out after 120s | 22 Sep 2026, 21:26
- SS-10B: Figure 14 — Wazuh Security Events after T1071.001: no network egress alert, no Sysmon EID 3 | 22 Sep 2026, 21:26
- SS-11A: Figure 15 — T1078.003 test execution: local admin account creation attempt | 22 Sep 2026, 21:28
- SS-11B: Figure 16 — Wazuh Security Events after T1078.003: Level 8 alerts T1098 + T1484 fired | 22 Sep 2026, 21:30
- SS-12A: Figure 17 — T1547.001 test execution: registry Run key added, exit code 0 | 22 Sep 2026, 21:34
- SS-12B: Figure 18 — Wazuh Security Events after T1547.001: no registry alert, no Sysmon EID 13 | 22 Sep 2026, 21:34